MeridianPay Financial Services: Incident Response, Resilience and Privacy Programme

Group Project Report | GRC Advisory Team Prepared for:
Folake Adeyemi, Chief Executive Officer,

MeridianPay Financial Services

Prepared by: Pod Orion (GRC Advisory Team)

Group members:

1. Moyinoluwa Aregbesola
2. Adenike Mutiat Adebayo
3. Blessing Ohaka

Date: 26 October 2026 | **Version:** 1.0 (Draft for management review) | **Classification:** Confidential

1. Executive Summary

MeridianPay has grown faster than its security and resilience arrangements. Last week a Customer Support employee clicked a phishing link and exposed their credentials, leading to suspicious account activity, possible unauthorised access to customer information and disruption to payment services. The company has no formal Incident Response (IR), Business Continuity (BCP) or Disaster Recovery (DR) plan, and its evidence handling and privacy documentation are inadequate.

The company processes about 150,000 transactions a day worth about ₦2.5 billion, generating about ₦18 million in daily revenue. It serves roughly 600,000 customers and 9,000 merchants, is regulated by the Central Bank of Nigeria (CBN) and processes personal data under the Nigeria Data Protection Act 2023 (NDPA). A four-person security team covers business hours only, while the platform runs 24/7.

This report describes the five objectives set by the CEO:

#	Deliverable	Section
1	Incident Response Plan and three playbooks (ransomware, phishing, data breach)	4 to 5
2	Business Impact Analysis and recovery targets	6
3	Business Continuity Plan for essential services	7
4	Crisis Communication template for key audiences	8
5	Data Protection Impact Assessment (customer onboarding and KYC)	9

2. Recommendations

1. Approve and adopt the IR Plan immediately and appoint an Incident Commander, a Privacy Lead and a Communications Lead.
2. Close the 24/7 monitoring gap through an on-call rota in the short term and a managed detection and response (MDR) service in the medium term.
3. Adopt the recovery targets in Section 6.4: payment processing and the merchant gateway recover within 1 hour (RTO) with no more than 5 minutes of data loss (RPO).
4. Treat the 10:00 settlement cut-off as a critical deadline with a dedicated manual fallback procedure.
5. Complete and approve the DPIA before further changes to KYC processing and implement the high-priority mitigations in Section 9.6.
6. Test everything: tabletop exercise within 30 days, phishing simulation within 60 days, failover test within 90 days.

3. Scope, Assumptions and Method

Scope

MeridianPay's wallet, merchant gateway, onboarding and KYC, settlement, customer support and fraud monitoring, and the cloud platform and staff systems that support them.

Assumptions (to be validated with management):

- The platform is hosted with a single cloud provider; multi-region architecture is not yet confirmed.
- Customer support agents (40) can view full customer profiles, including KYC data, without role-based restrictions or session monitoring.
- Multi-factor authentication (MFA) is not enforced on all staff accounts. This is a likely contributor to the phishing incident.
- Backups exist but have not been restore-tested.
- Regulatory notification timelines must be confirmed against current CBN circulars and Nigeria Data Protection Commission (NDPC) guidance before go-live.

Method: Document review of the brief, alignment to ISO/IEC 27001 and 27035 (incident management), ISO 22301 (business continuity), NIST SP 800-61 (incident handling), NDPA 2023 and CBN requirements for payment service providers.

4. Incident Response Plan (IRP)

4.1 Document control

Item	Detail
Owner	Chief Information Security Officer (or Head of Security if no CISO)
Approver	Chief Executive Officer
Review cycle	Annually, and after every major incident or exercise
Distribution	Executive team, security team, IT operations, Customer Support leads, Legal, Compliance, Communications

4.2 Purpose and objectives

This plan sets out how MeridianPay detects, assesses, contains, eradicates and recovers from cyber incidents, preserves evidence and meets its legal and regulatory notification duties.

Objectives:

- Reduce time to detect and time to contain.

- Protect customer funds, customer data and service availability.
- Preserve evidence in a forensically sound manner.
- Meet CBN and NDPA obligations on time.
- Provide clear roles so that decisions are not delayed during an incident.

4.3 Scope and definitions

The plan applies to all employees, contractors and third parties with access to MeridianPay systems or data. An event is any observable occurrence; an incident is an event that actually or potentially compromises confidentiality, integrity or availability, or breaches policy. A personal data breach is a security breach that results in accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to personal data.

4.4 Incident response team and roles

Role	Responsibilities	Primary / Alternate
Incident Commander (IC)	Leads response, declares severity, authorises containment, owns decision log	Head of Security / Head of IT
Technical Lead	Investigation, containment, eradication, recovery	Senior Security Engineer / Cloud Lead
Forensics and Evidence Lead	Evidence collection, chain of custody, log preservation	Security Analyst / external DFIR retainer
Privacy Lead / DPO	Personal data breach assessment, NDPC and data subject notification	DPO / Legal Counsel
Compliance Lead	CBN reporting, partner bank and regulator liaison	Head of Compliance
Communications Lead	Internal, customer, merchant, media messaging	Head of Marketing / Corporate Affairs
Operations Lead	Service continuity, invoke BCP, settlement decisions	Head of Operations
Customer Support Lead	Customer handling scripts, call surge management	Support Manager
Executive Sponsor	Strategic decisions, regulator and board communication	CEO / COO
Scribe	Maintains timeline and decision log	Any trained staff member

Responsibility and Accountability Matrix (RACI)

The following matrix clarifies responsibility for key incident response activities. RACI means Responsible (R), Accountable (A), Consulted (C) and Informed (I).

Activity	Incident Commander	Technical Lead	Privacy/DPO	Compliance Lead	Communications Lead	Operations Lead	CEO
Classify incident severity	A	R	C	C	I	C	I
Contain technical threat	A	R	C	I	I	C	I
Assess personal data exposure	C	R	A	C	I	I	I
Determine regulatory notifications	I	C	C	A/R	I	C	I
Activate Business Continuity Plan	C	C	I	I	I	A/R	I
Approve major external communications	C	C	C	C	R	C	A
Approve service recovery	A	R	C	I	I	R	I
Complete post-incident review	A/R	C	C	C	C	C	I

The Incident Commander remains accountable for coordinating the overall response. Specialist responsibilities remain with the relevant technical, privacy, compliance and operational leads. The CEO or authorised executive makes decisions reserved for executive approval.

Out-of-hours coverage: an on-call rota with a named IC and Technical Lead every day of the week, reachable within 15 minutes. Contact details are held in the Emergency Contact Sheet (Appendix A).

4.5 Severity classification

Level	Definition	Examples	Response time	Escalation
SEV-1 Critical	Confirmed major impact on payments, customer funds or large-scale personal data	Ransomware on production, confirmed bulk data exfiltration, payment platform down	Immediate (15 min)	CEO, Board, CBN, DPO
SEV-2 High	Significant impact or credible risk of SEV-1	Compromised privileged or support account with data access, partial outage	30 min	Executive team, DPO
SEV-3 Medium	Limited impact, contained	Single compromised account with no data access, malware on one endpoint	4 hours	Head of Security
SEV-4 Low	Minor or policy violation	Reported phishing email, nobody clicked	Next business day	Security team

Note: last week's incident should be classified at minimum SEV-2 until the scope of data access is confirmed.

Incident Escalation Triggers

Incident indicator	**Minimum escalation**	**Required action**
Phishing email reported, but no link clicked and no credentials entered	SEV-4	Preserve the email, block confirmed malicious indicators and check whether other staff received it.
Credentials entered or suspicious sign-in detected	SEV-3; escalate to SEV-2 if customer data or payment systems may be accessible	Restrict the account, revoke active sessions, reset credentials and review access logs.
Possible unauthorised access to customer information	At least SEV-2 pending investigation	Preserve logs, restrict access and involve the Privacy Lead/DPO.
Ransomware affecting production systems or significant payment disruption	SEV-1	Activate the Incident Response Team and BCP, isolate affected systems and protect backups.

Suspected fraud, transaction manipulation or risk to customer funds	SEV-1 where impact is major or widespread	Involve Fraud and Operations, preserve transaction evidence and contact affected partner banks as required.
Incident threatens the 10:00 settlement cut-off	At least SEV-2; SEV-1 if there is major payment impact	Notify Operations and Finance immediately and assess the approved settlement fallback procedure.
Suspected personal data breach	Severity based on impact; involve the Privacy Lead/DPO immediately	Begin the documented privacy assessment and determine applicable notification obligations.

The response times in Section 4.5 are internal response targets, not regulatory notification deadlines. If the severity is unclear, the Incident Commander should assign a reasonable provisional severity and raise it as new evidence becomes available. All severity changes and escalation decisions must be documented in the incident log.

4.6 Incident response lifecycle

Phase	Key actions	Output
1. Preparation	Maintain tooling, logging, backups, contact lists, DFIR retainer, training and exercises	Readiness checklist
2. Detection and reporting	Monitor alerts (SIEM, EDR, fraud engine), staff report via security hotline or email; triage within SLA	Incident ticket
3. Analysis and classification	Validate, scope affected systems, accounts and data, assign severity, decide whether personal data is involved	Severity and scope assessment
4. Containment	Short-term: isolate hosts, disable accounts, revoke sessions and tokens, block indicators. Long-term: segment networks, apply temporary controls	Containment log
5. Eradication	Remove malware and persistence, reset credentials, patch exploited weaknesses	Eradication confirmation
6. Recovery	Restore from clean backups, monitor closely, staged return to service, validate integrity of transactions and balances	Recovery sign-off
7. Post-incident review	Lessons-learned meeting within 5 working days, root cause, action plan with owners and dates	Post-incident report

4.7 Evidence handling and chain of custody

Poor evidence handling is a current weakness. The following rules apply to every SEV-1 to SEV-3 incident:

1. Preserve before remediating where safe: capture volatile data (memory, running processes, network connections), then disk images or cloud snapshots.
2. Never work on originals**:** Use forensic copies and verify with cryptographic hashes (SHA-256).
3. Log all evidence in the Evidence Register: item ID, description, source, collector, date and time (with time zone), hash, storage location.
4. Maintain chain of custody: every transfer is recorded with names, dates and reasons.
5. Preserve logs (authentication, VPN, cloud audit, application, email gateway, EDR) for at least 12 months; apply legal hold to incident-related logs.
6. Store evidence in a restricted, access-logged repository; limit access to the IR team and legal.
7. Synchronise time across systems and record time offsets.
8. Engage external forensics for SEV-1 incidents or where litigation or regulator action is likely.

Evidence collection must not unnecessarily delay urgent containment actions needed to protect customer funds, personal data or essential services. Where immediate containment is necessary, the Incident Commander and Technical Lead should document the actions taken, the reason for them and any evidence that could not be collected beforehand. Evidence must be stored securely, access-restricted and available for authorised investigation, legal review and regulatory enquiries.

4.8 Regulatory and legal notification matrix

Obligation	Trigger	Deadline (confirm current rules)	Owner
NDPC notification (NDPA 2023)	Personal data breach is likely to result in risk to individuals' rights and freedoms	Within 72 hours of becoming aware	Privacy Lead / DPO
Data subject notification (NDPA 2023)	Breaches are likely to result in high risk to individuals	Without undue delay, with clear guidance on protective steps	Privacy Lead with Communications
CBN incident reporting	Material cyber incident or service disruption affects a licensed payment provider	Per applicable CBN circular (confirm timeline; treat as same-day for SEV-1)	Compliance Lead
Partner banks	Incident affecting settlement, fraud exposure or shared data	Immediately for SEV-1 and SEV-2 impacting settlement	Operations and Compliance

Obligation	Trigger	Deadline (confirm current rules)	Owner
Law enforcement	Suspected criminal activity, ransom demand	At CEO and Legal discretion, early for ransomware and fraud	Legal
Cyber insurer	If a policy exists	Per policy terms, typically immediate	Finance / Legal

4.9 Decision rules for key judgement calls

- Take the payment platform offline? Only the IC, with Operations Lead and CEO consultation, when continued operation risks customer funds or data integrity. Prefer targeted isolation first.
- Pay a ransom? Not authorised by default. Any consideration requires CEO, Board, Legal, and law enforcement involvement, plus sanctions screening.
- Notify without full facts? Yes. Notify on a *what we know, what we are doing, what we do not yet know* basis rather than wait for certainty.

4.10 Post-incident review and metrics

Track: mean time to detect (MTTD), mean time to contain (MTTC), mean time to recover (MTTR), number of customers affected, regulatory deadlines met, and actions closed on time. Present quarterly to the executive team.

5. Incident Response Playbooks

Minimum Requirements for All Playbooks

Each playbook must identify the incident trigger, initial severity, responsible owner, escalation point, containment actions, evidence to preserve, communication requirements and recovery approval criteria. Every action should be recorded with its owner, timestamp and outcome.

An incident must not be considered resolved solely because the immediate threat has stopped. Before closure, the Incident Commander must confirm that the threat has been contained, affected systems and accounts have been assessed, recovery has been validated, required notifications have been considered, and corrective actions have been assigned to named owners with due dates.

5.1 Playbook A: Phishing and credential compromise

Trigger: staff report a suspicious email, a user clicks a link or enters credentials, or alerts show anomalous sign-ins.

Default severity: SEV-3, raised to SEV-2 if the account has access to customer data or payment systems (as in the current incident).

Step	Action	Owner	Target time
1	Receive report; open ticket; record who, what, when, and which link or attachment	Security analyst	15 min
2	Preserve the email (headers and original) and URL; take screenshots	Forensics Lead	30 min
3	Disable the affected account; revoke all sessions, refresh tokens and API keys; force password reset and re-register MFA	Technical Lead	30 min
4	Review sign-in logs, mailbox rules (check for forwarding), MFA changes, VPN and cloud activity for the previous 30 days	Technical Lead	2 hours
5	Review the account's access to customer data: queries, exports, profile views, admin actions	Technical Lead and Privacy Lead	4 hours
6	Search and purge the same email from all mailboxes; block sender, domain and URL at gateway and DNS	Technical Lead	1 hour
7	Check for lateral movement and other affected users; scan endpoint with EDR	Technical Lead	4 hours
8	If customer data was accessed or exfiltrated, invoke **Playbook C**	Incident Commander	Immediate
9	Notify affected staff and brief all employees on the lure; no blame	Communications Lead	24 hours
10	Recovery: restore account access with MFA and least privilege; heightened monitoring for 30 days	Technical Lead	24 hours
11	Post-incident: targeted awareness training, phishing-resistant MFA, conditional access, email authentication (SPF, DKIM, DMARC)	Security Lead	30 days

Decision points: if funds movement, fraud or admin changes appear in logs, escalate to SEV-1 and inform the fraud team and partner banks.

5.2 Playbook B: Ransomware

Trigger: encrypted files, ransom note, mass file changes, EDR ransomware alert, unexplained service failure.

Default severity: SEV-1.

Phase	Action	Owner
Detect	Confirm via EDR and system evidence; do not power off affected machines if memory capture is needed	Technical Lead
Declare	IC declares SEV-1; activate the IR team, Operations Lead and Executive Sponsor; open a secure out-of-band communication channel (assume email may be compromised)	Incident Commander
Contain (first hour)	Isolate affected hosts and network segments; disable compromised accounts; block command-and-control; suspend VPN and remote access if needed; protect backups by disconnecting backup systems and revoking their credentials	Technical Lead
Protect payments	Decide whether to suspend processing; invoke BCP for settlement; alert partner banks and fraud team	Operations Lead and IC
Preserve evidence	Memory capture, disk images, ransom note, wallet addresses, logs; hash and register	Forensics Lead
Assess	Identify patient zero, entry point, spread, data theft (double extortion). Assume data exfiltration until disproved; if confirmed, invoke Playbook C	Technical Lead and Privacy Lead
Notify	CBN, partner banks, NDPC (if personal data affected), law enforcement, insurer, DFIR retainer	Compliance and Legal
Eradicate	Rebuild affected systems from known-good images; reset all privileged credentials and secrets, including service accounts and API keys; patch the entry vector	Technical Lead
Recover	Restore from verified, offline or immutable backups; scan restored data; staged reintroduction with enhanced monitoring; reconcile transactions and balances before reopening	Operations and Technical Lead
Review	Root cause, control gaps, cost, regulator follow-up	Incident Commander

Ransom policy: no payment authorisation without Board approval, legal advice, sanctions checks and law enforcement consultation.

5.3 Playbook C: Personal data breach

Trigger: confirmed or suspected unauthorised access, disclosure, loss or alteration of personal data (including customer KYC data, IDs, selfies, transaction data).

Default severity: SEV-2, SEV-1 if large-scale or sensitive data is involved.

Step	Action	Owner	Target time
1	Contain: stop the access or leak; revoke credentials; remove exposure	Technical Lead	Immediate
2	Start the breach register entry and the 72-hour clock from the moment MeridianPay becomes aware	Privacy Lead	1 hour
3	Establish facts: what data, how many people, which categories (identity documents, selfies, account data), time, cause	Technical and Privacy Leads	24 hours
4	Assess risk to individuals: likelihood and severity of identity theft, fraud, financial loss, distress; consider data sensitivity and ease of identification	Privacy Lead	24 hours
5	Decide on notification: NDPC if risk; data subjects if high risk; document the reasoning even if no notification is made	Privacy Lead with Legal, approved by IC	48 hours
6	Notify NDPC within 72 hours (nature of breach, categories and approximate numbers, likely consequences, measures taken, DPO contact). Phase information if incomplete	Privacy Lead	Within 72 hours
7	Notify affected individuals in plain language: what happened, what data, what we are doing, what they should do, how to contact us	Communications and Privacy Leads	Without undue delay
8	Notify CBN, partner banks and any controllers or processors affected, as contract requires	Compliance Lead	Per matrix
9	Offer protective measures: password and PIN resets, enhanced fraud monitoring, guidance on ID misuse	Customer Support and Fraud	As needed
10	Review controls and update the DPIA and Record of Processing Activities (RoPA)	Privacy Lead	30 days

Evidence to retain: access logs, query and export logs, the breach assessment, decision rationale, notification copies and submission receipts.

6. Business Impact Analysis (BIA)

6.1 Purpose and method

The BIA identifies MeridianPay's critical activities, the impact of their disruption over time, their dependencies, and the recovery targets needed to keep the business within tolerable limits. Impacts were rated across four categories: financial, regulatory and legal, customer and merchant, and reputational, on a scale of 1 (minor) to 5 (severe) at 1 hour, 4 hours, 8 hours and 24 hours of outage.

Definitions:

- **MTD (MTPD)** (Maximum Tolerable Period of Disruption): the point beyond which the business cannot survive or comply.
- **RTO** (Recovery Time Objective): target time to restore the activity.
- **RPO** (Recovery Point Objective): maximum tolerable data loss, measured in time.
- **MBCO** (Minimum Business Continuity Objective): minimum service level acceptable during disruption.

6.2 Financial baseline (from the brief)

Metric	Value	Derived figure
Daily transactions	about 150,000	about 6,250 per hour on average
Daily transaction value	about ₦2.5 billion	about ₦104 million per hour
Daily revenue	about ₦18 million	about ₦0.75 million per hour (about ₦5.6 million over a 7.5-hour business day)
Customers / merchants	600,000 / 9,000	Wallet and gateway users
New accounts per day	about 800	KYC onboarding pipeline

Direct revenue loss is only part of the impact. Regulatory penalties, fraud losses, chargebacks, customer churn, and remediation costs are not included and could substantially exceed lost revenue during a prolonged outage.

6.3 Critical activity impact assessment

Activity	1 hour	4 hours	8 hours	24 hours	Key impact drivers
24/7 payment processing (wallet and merchant gateway)	4	5	5	5	Revenue loss, merchant failed sales, CBN scrutiny, loss of trust

Activity	1 hour	4 hours	8 hours	24 hours	Key impact drivers
Settlement with partner banks (10:00 cut-off)	2 (outside cut-off) / 5 (near cut-off)	5	5	5	Failed settlement, liquidity strain, contractual breach, regulatory reporting
Fraud monitoring	3	4	5	5	Undetected fraud, reduced control during incident, higher losses
Customer support	2	3	4	4	Complaints surge, no incident communications channel, reputational harm
Customer onboarding and KYC	1	2	3	4	Lost sign-ups (about 800 a day), compliance backlog
Security monitoring and IR	3	4	5	5	Undetected compromise, delayed containment
Finance, reconciliation and reporting	1	2	3	4	Reconciliation breaks, delayed regulatory returns
Corporate IT (email, collaboration, identity)	2	3	4	4	Coordination failure, inability to communicate

6.4 Recovery targets

Priority	Activity	MTPD	RTO	RPO	MBCO (minimum service during disruption)
Tier 1	Payment processing and merchant gateway	4 hours	1 hour	5 minutes	Process core wallet transfers and merchant payments; throttle non-critical features
Tier 1	Settlement with partner banks	Before the next 10:00 cut-off	2 hours (and complete before cut-off)	0 (no loss of settled transactions)	Manual or file-based settlement with partner banks under dual control

Priority	Activity	MTPD	RTO	RPO	MBCO (minimum service during disruption)
Tier 1	Fraud monitoring	4 hours	1 hour	5 minutes	Rules-based monitoring and manual review of high-value transactions; velocity limits
Tier 1	Identity and access management and security monitoring	4 hours	2 hours	15 minutes	Core authentication and logging; on-call analyst monitoring
Tier 2	Customer support	24 hours	4 hours	1 hour	Reduced team with restricted profile access, scripted responses, status page
Tier 2	Corporate email and collaboration	24 hours	4 hours	1 hour	Secondary communications channel (see 8.2)
Tier 3	Customer onboarding and KYC	72 hours	8 hours	1 hour	Queue applications; tiered accounts with low limits until KYC completes
Tier 3	Finance, reconciliation and reporting	72 hours	24 hours	4 hours	Manual reconciliation, deferred reporting

Targets are proposed for management approval. They must be validated against cloud architecture, partner bank agreements and CBN requirements.

Recovery Target Validation

The proposed recovery targets should be reviewed and approved by management and the relevant service owners. The RTOs must remain shorter than the maximum tolerable downtime (MTD), while the RPOs must be supported by actual backup, replication and transaction-log capabilities. The proposed five-minute RPO for payment processing should be validated through testing. Operations and Finance should also confirm, with each partner bank, the latest time to activate fallback procedures to meet the 10:00 settlement cut-off. Settlement records must remain accurate and reconcilable after recovery.

6.5 Dependencies and single points of failure

Dependency	Supports	Risk	Recommendation
Cloud hosting provider (region and availability zones)	All Tier 1 services	Single region failure or misconfiguration	Multi-AZ at minimum; warm standby in a second region for Tier 1
Three partner banks	Settlement	Cut-off missed, bank outage	Agreed contingency procedures and contacts with each bank
Core database and backups	Payments, wallets, KYC	Backup corruption, ransomware reaching backups	Immutable, offline and cross-region backups; quarterly restore tests
Identity provider and MFA	All staff access	Compromise or outage	Break-glass accounts, phishing-resistant MFA for privileged users
Four-person security team	Detection and IR	Key-person dependency, no 24/7 cover	On-call rota, MDR service, DFIR retainer
Third-party KYC and ID verification services (if used)	Onboarding	Vendor outage	Queueing, manual verification fallback
Telecom and internet connectivity	Staff and platform	Link failure	Dual ISPs, mobile hotspots, remote working capability

6.6 Key findings

1. The platform operates 24/7 but security monitoring and response run only in business hours. Attacks outside those hours go unnoticed.
2. The 10:00 settlement cut-off creates a daily deadline: an incident overnight or early morning has disproportionate impact.
3. Recovery capability is unproven because no restore or failover tests have been performed.
4. Customer support access to full profiles amplifies the impact of any support-account compromise.

7. Business Continuity Plan (BCP)

7.1 Purpose, scope and activation

This plan keeps MeridianPay's essential services running, or restore them within the RTOs in Section 6.4, during a disruptive event such as a cyber incident, cloud outage, power or connectivity failure, loss of premises or key suppliers, or loss of key staff.

Scope: Tier 1 and Tier 2 services in full, Tier 3 services in a reduced form.

Activation criteria (anyone):

- A Tier 1 service is unavailable or degraded beyond 15 minutes.
- An incident is declared SEV-1 or a SEV-2 that threatens an RTO.

- The Incident Commander or COO requests activation.

Authority: The COO (or CEO if unavailable) activates the BCP on the advice of the Incident Commander and Operations Lead. Activation is recorded in the decision log.

7.2 Continuity governance

Role	Responsibilities
BCP Coordinator (Operations Lead)	Runs the plan, maintains documents, convenes the Continuity Team
Continuity Team	Heads of Engineering, Operations, Support, Finance, Compliance, Security, HR, Communications
Service owners	Execute recovery procedures for their service and report status every 30 minutes
Executive Sponsor	Resolves priority conflicts, authorises customer-impacting trade-offs

7.3 Continuity strategies by essential service

Service	Disruption scenario	Continuity strategy	Owner
Payment processing and gateway	Production compromise, cloud zone or region failure, ransomware	Fail over to secondary availability zone or standby region; restore from last verified backup if required; enable degraded mode (core transfers and merchant payments only); apply temporary transaction limits; publish status page updates	Head of Engineering
Settlement	Systems unavailable before 10:00 cut-off	Generate settlement files from the last reconciled ledger; manual submission through approved bank channels with dual authorisation; early engagement with each partner bank; request cut-off extension where possible	Head of Finance and Operations
Fraud monitoring	Tooling outage or compromise	Switch to reduced rule set and manual review of high-risk and high-value transactions; tighten velocity and amount limits	Head of Fraud
Customer support	Support platform or staff unavailable; surge in contacts	Activate scripted responses; redirect to status page and in-app notices; reduce profile access to least privilege; remote working; overflow to trained staff from other teams	Support Manager

Service	Disruption scenario	Continuity strategy	Owner
Onboarding and KYC	Platform or KYC vendor outage	Queue applications; offer limited-function wallets with low limits pending verification; manual review for priority cases	Compliance Lead
Security operations	Team unavailable out of hours	On-call rota; MDR provider; DFIR retainer on call	Head of Security
People	Staff unavailable or key-person loss	Cross-training, named alternates for every critical role, call tree	HR and department heads
Premises and connectivity	Office inaccessible, power or ISP failure	Remote working for all critical roles, backup generator and dual ISP, mobile data fallback	Head of IT and Facilities
Suppliers	Cloud, bank, KYC or telecom provider failure	Supplier contact sheet, escalation paths, contractual SLAs, alternative provider assessment	Procurement and Operations

7.4 Disaster recovery (technical) requirements

Control	Requirement
Backups	Daily full plus continuous or 5-minute incremental for transaction databases; encrypted; immutable copy stored in a separate account and region; offline copy for critical data
Restore testing	At least quarterly for Tier 1; results recorded and defects fixed
Replication	Synchronous or near-synchronous replication to a secondary zone; asynchronous to a second region
Infrastructure as code	Environments rebuildable from version-controlled templates
Failover runbooks	Step-by-step, tested, accessible offline (printed or stored outside the primary environment)
Break-glass access	Sealed, monitored emergency admin accounts independent of the primary identity provider
Monitoring	Health checks and alerts routed 24/7 to the on-call engineer

7.5 Recovery sequence (cyber-related outage)

Order	Action	Target time from activation
1	Convene Continuity Team and open secure communications channel	15 min
2	Confirm status of Tier 1 services and last known good recovery point	30 min
3	Contain threat (coordinate with IR playbooks)	30 to 60 min
4	Fail over or restore payment processing and gateway in degraded mode	Within 1 hour
5	Restore fraud monitoring before or with payments	Within 1 hour
6	Execute settlement fallback if the 10:00 cut-off is at risk	Before cut-off
7	Restore identity, security monitoring and customer support access	Within 2 to 4 hours
8	Restore onboarding and KYC	Within 8 hours
9	Reconcile transactions, validate balances, remove temporary restrictions	Before return to normal
10	Stand down and complete post-incident review	Within 5 working days

7.6 Testing and maintenance

Activity	Frequency
Plan review and update	Annually and after material change or incident
Tabletop exercise (ransomware, phishing and breach scenarios)	Within 30 days of approval, then twice a year
Backup restore test	Quarterly
Failover test of Tier 1 services	Within 90 days, then annually
Call tree test	Quarterly
Settlement fallback drill with a partner bank	Annually

Track exercise findings as actions with owners and due dates and report them to the executive team.

8. Crisis Communication Plan and Template

8.1 Principles

Speed with accuracy: acknowledge early, update on a fixed schedule, never speculate.

One voice: all external statements are approved by the Communications Lead, Legal and the Executive Sponsor.

Honesty and care: say what happened, what is affected, what we are doing and what people should do.

Consistency: all audiences receive the same facts, tailored in tone and detail.

Do not blame individuals, including the staff members who clicked the phishing link.

8.2 Crisis communications team and channels

Role	Responsibility
Communications Lead	Drafts and publishes all messages, manages the media queue
Executive Sponsor (CEO)	Approves SEV-1 statements, is the spokesperson for major incidents
Legal and Compliance	Review for regulatory and legal accuracy
Privacy Lead	Confirms personal data statements
Customer Support Lead	Briefs agents, feeds back customer concerns

Channels: status page (hosted independently of the main platform), in-app notice, SMS and email to customers, merchant portal and account managers, social media, press statement, internal email and messaging.

Secondary channel**:** a pre-agreed external messaging group for the crisis team, used if corporate email is compromised.

8.3 Audience and message matrix

Audience	Primary concerns	Channel	Owner	First message within	Update frequency
Employees	What happened, what to do, what not to say publicly	Internal email, all-hands	Communications Lead and HR	1 hour	Every 4 hours (SEV-1)
Customers	Is my money safe, is my data affected, what should I do	SMS, in-app, email, status page	Communications Lead	2 hours	Every 4 hours or on change

Audience	Primary concerns	Channel	Owner	First message within	Update frequency
Merchants	Can I take payments, when will settlements arrive	Portal, email, account managers	Merchant Success Lead	1 hour	Every 2 hours during outage
Regulators (CBN, NDPC)	Facts, impact, remedial action, timeline	Formal notice and direct contact	Compliance Lead and DPO	Per matrix in 4.8	As required
Partner banks	Settlement impact, fraud exposure	Phone then written	Head of Finance	Immediately for SEV-1 and SEV-2	Hourly during settlement risk
Board and investors	Exposure, response, decisions needed	Phone, secure email	CEO	2 hours	Every 6 hours
Media	Facts and reassurance	Holding statement, press release	Communicatio ns Lead	On enquiry or if public	As needed
Law enforcement / insurer	Evidence and support	Direct	Legal	As decided	As needed
Third-party vendors	Coordination	Direct	Head of Operations	As needed	As needed

8.4 Message approval workflow

Draft (Communications) → Fact check (Technical Lead and Privacy Lead) → Legal and Compliance review → Executive approval → Publish → Log in decision record. For SEV-1, the target is 60 minutes from draft to publication; pre-approved holding statements may be released immediately.

8.5 Message templates

Template A: Holding statement (public and media)

*MeridianPay is aware of [a technical issue / a security incident] affecting [service] since [time, date]. Our teams are working to restore normal service and have **[**engaged specialist support**]**. We are taking this matter seriously and will provide further updates by [time] on [status page URL]. [If true:] At this time, we have no evidence that customer funds have been affected. Customers can contact us on [channel].*

Template B: Customer notification (service disruption)

Subject: Update on MeridianPay services

Dear customer,

On [date and time], we experienced [brief description]. [Services affected] may be unavailable or slow. Your funds remain [secure / protected]. [Remove if not confirmed.]

We are working to restore full service and expect [timeline or next update time]. In the meantime: [alternative actions].

We apologise for the inconvenience. For help, contact [channel]. Latest updates: [status page].

MeridianPay Customer Care

Template C: Customer notification (personal data breach)

Subject: Important notice about your personal information

Dear [name],

We are writing to tell you about a security incident that may affect your personal information.

What happened: On [date], we detected [description in plain language].

What information was involved: [categories, e.g. name, phone number, account details, ID number]. [State clearly what was NOT affected, e.g. PINs or passwords, if confirmed.]

What we are doing: [containment, investigation, notified regulators, strengthened controls].

What you can do: change your password and PIN; be cautious of calls, SMS or emails asking for your details or OTP; MeridianPay will never ask for your PIN or full password; check your transaction history and report anything unusual to [contact].

Contact us: [dedicated phone and email]. You also have the right to lodge a complaint with the Nigeria Data Protection Commission.

We sincerely apologise for this incident.

[Name], [Title], MeridianPay Financial Services

Template D: Merchant notice

Subject: Payment gateway status: [service]

Dear partner, since [time] [description of issue] may affect [transactions / settlements]. Transactions processed before [time] are [unaffected / being reconciled]. Settlement for [date] is [expected on schedule / may be delayed to ...]. Your account manager is [name, contact]. Next update: [time].

Template E: Internal staff message

Subject: Security incident: what you need to know

We are responding to [brief description]. Please: (1) do not discuss this externally or on social media, and refer all enquiries to [contact]; (2) report any suspicious email, call or system behaviour to [security hotline] immediately; (3) [specific actions, e.g. reset password]. We will update you by

[time]. Reporting a mistake quickly helps us protect customers, and nobody will be penalised for good-faith reports.

Template F: Regulator notification (CBN and NDPC outline)

Field	Content
Organisation and contact	MeridianPay Financial Services, DPO and Compliance Lead contact details
Date and time incident occurred / was detected	
Nature of the incident	Type, systems affected, current status
Data and individuals affected	Categories and approximate numbers of people and records
Likely consequences	Risks to individuals and to financial services
Measures taken and planned	Containment, remediation, mitigation for individuals
Communication to individuals	Whether, when and how
Further information	Date of next update

Template G: Management and Board update

Subject: [SEV level] incident update [number]: [short description]

Dear [Board members / Executive team], this is update [number] on [incident]. Status: [under investigation / contained / recovering]. Impact: [services, customers and merchants affected; estimated financial exposure]. Personal data: [whether affected, categories and approximate numbers; state clearly what is not yet known]. Actions taken: [containment, specialist support, partner banks and regulators informed]. Regulatory position: [CBN and NDPC notifications made or planned, with deadlines]. Decisions required from you: [e.g. approve customer notification, authorise service suspension, approve external forensics]. Next update: [time]. This message is confidential; please do not forward it outside the distribution list. [Name], [Title], MeridianPay Financial Services

8.6 Customer Support handling guide

- Agents use only approved scripts and do not speculate on cause or numbers.
- Verify identity before discussing account details; never ask for PINs, OTPs or full passwords.
- Log all incident-related contacts with a tag for trend analysis and potential fraud reports.
- Escalate suspected account takeover to the fraud team immediately.

8.7 Post-crisis communication

Issue a closing update when service is restored and verified, publish a summary of lessons learned and improvements for customers where appropriate, and measure sentiment, complaint volumes and churn for 90 days.

9. Data Protection Impact Assessment (DPIA)

Processing activity assessed: Customer onboarding and Know Your Customer (KYC) verification

Selected because it processes ID numbers, identity documents and facial images (selfies) for about 800 new accounts a day, uses large-scale personal data of a financial nature, and is the activity most exposed to identity theft and fraud if compromised.

9.1 Document control

Item	Detail
Controller	MeridianPay Financial Services
DPO / Privacy Lead	To be named
Assessment date	26 October 2026
Status	Draft, pending DPO and executive approval
Review	Annually or on material change

9.2 Description of the processing

Element	Description
Purpose	Verify customer identity, meet CBN KYC and anti-money-laundering (AML) obligations, prevent fraud, open wallets
Data subjects	Prospective and existing customers (individual consumers); about 800 new applicants daily
Personal data	Full name, date of birth, phone, email, address, national identification numbers (such as NIN or BVN where required), government ID document images, selfie or liveness images, device and location data, onboarding risk scores
Special or sensitive data	Facial images used for identity verification are biometric in nature if used for facial matching, which is treated as sensitive personal data under the NDPA. Confirm whether matching is performed

Element	Description
Source	Directly from the individual through the app or website; verification responses from third-party or government identity services
Recipients	Onboarding and compliance staff, customer support (limited), fraud team, KYC and identity verification vendors, partner banks, regulators on request
Systems	Mobile app and web, cloud-hosted KYC database and document store, verification vendor APIs, case management
Retention	Per regulatory requirements (typically at least 5 to 6 years after relationship ends under financial regulation; confirm). Rejected applications to be defined (proposed 12 months)
Transfers	Possible cross-border transfers where cloud or vendor infrastructure is outside Nigeria; assess under NDPA cross-border rules
Scale	600,000 existing customers, about 800 new accounts per day, about 290,000 per year

9.3 Lawful basis and necessity

Question	Assessment
Lawful basis	Legal obligation (CBN KYC and AML requirements) for core verification; contract for account opening; legitimate interest for fraud prevention (with balancing test); consent for any optional use, such as marketing or biometric use not required by law
Necessity and proportionality	Collection of ID numbers and documents is required by regulation. Selfies are proportionate where required for liveness and identity matching. Collection beyond what is required (for example, extra documents) should stop
Data minimisation	Review whether full document images need to remain accessible to support agents after verification
Transparency	Privacy notice must explain KYC purposes, vendors, retention and rights at the point of collection. *Gap: documentation inadequate per the brief*
Data subject rights	Procedures needed for access, rectification, erasure (subject to legal retention), objection and complaints

Question	Assessment
Accuracy	Verification against authoritative sources; correction process
Processors	Data processing agreements with all vendors, including security and breach notification duties

9.4 Consultation

DPO, Compliance, Security, Engineering, Customer Support and KYC vendors consulted. Customer input recommended through a user-testing or survey of the new privacy notice. The NDPC should be consulted if residual risk remains high after mitigation.

9.5 Risk assessment

Likelihood (L) and Severity (S) rated 1 to 5. Score = L × S. High: 15 or above; Medium: 8 to 14; Low: 7 or below.

ID	Risk to individuals	L	S	Score	Rating
R1	Unauthorised access to KYC data through compromised staff credentials (the current threat scenario), leading to identity theft and fraud	4	5	20	High
R2	Excessive internal access: support agents can view full profiles and ID documents without need	4	4	16	High
R3	Large-scale exfiltration of ID documents and selfies from the document store or backups	3	5	15	High
R4	Breach at a KYC or identity verification vendor	3	4	12	Medium
R5	Retention of data longer than needed (no defined retention schedule)	4	3	12	Medium
R6	Inadequate transparency, individuals unaware of how data is used	4	3	12	Medium
R7	Delayed breach detection and notification due to no 24/7 monitoring or IR plan	4	4	16	High
R8	Cross-border transfer without adequate safeguards	2	4	8	Medium
R9	Inaccurate matching or biased facial verification leading to wrongful rejection	2	3	6	Low
R10	Misuse of data for unrelated purposes (function creep)	2	4	8	Medium

9.6 Mitigation measures

Risk	Measure	Owner	Priority and timeline	Residual risk
R1, R7	Enforce MFA (phishing-resistant for privileged users), conditional access, session timeouts, UEBA alerts on unusual data access, 24/7 monitoring via MDR, IR Plan adoption	Head of Security	Immediate to 30 days	Medium
R2	Role-based access control and least privilege; mask sensitive fields (ID numbers, document images) by default; just-in-time access with approval and logging for unmasking; monitor and alert on bulk views and exports	Head of Engineering and Support	30 days	Low
R3	Encrypt data at rest (customer-managed keys) and in transit; separate the document store; restrict network access; immutable backups; data loss prevention; regular access reviews	Head of Engineering	**60 days**	Medium
R4	Vendor due diligence, data processing agreements with breach notification within 24 to 48 hours, right to audit, security certifications	Procurement and DPO	60 days	Low
R5	Retention schedule with automated deletion or anonymisation; secure deletion of rejected applications	DPO and Engineering	90 days	Low
R6	Layered privacy notice, in-app just-in-time notices, plain-language language options	DPO and Communications	30 days	Low
R8	Map data flows, apply transfer safeguards and contractual clauses, prefer in-country or approved regions	DPO and Legal	90 days	Low
R9	Manual review route and appeal process; vendor accuracy testing	Compliance	90 days	Low
R10	Purpose limitation policy, access logging, periodic audit	DPO	90 days	Low

9.7 Conclusion and sign-off

After implementing mitigations R1, R2, R3 and R7 as a priority, residual risk is assessed as Medium and acceptable, subject to DPO approval and monitoring. Without these measures, processing should not expand. If the 30-day measures are not delivered, the DPO should consult the NDPC before continuing high-risk processing.

Role	Name	Decision	Date
Project owner (Head of Compliance)			
DPO / Privacy Lead		Approve / Approve with conditions / Reject	
CISO / Head of Security			
CEO (accepting residual risk)			

10. Implementation Roadmap

Horizon	Actions	Owner
Immediate (0 to 14 days)	Approve IR Plan and name the IC, Privacy Lead and Communications Lead; complete investigation of last week's incident under Playbooks A and C and decide on NDPC notification; enforce MFA and reset exposed credentials; set up on-call rota and secure out-of-band communications; engage DFIR retainer	CEO, Head of Security
30 days	Run the first tabletop exercise; restrict support access to customer data (masking and logging); publish privacy notice improvements; approve BIA recovery targets; begin phishing awareness campaign	Security, Support, DPO
60 days	Immutable and cross-region backups with first restore test; deploy MDR or 24/7 monitoring; vendor agreements reviewed; phishing simulation; DMARC enforced	Engineering, Procurement
90 days	Failover test for Tier 1 services; settlement fallback drill with partner banks; retention schedule implemented; DPIA actions closed; first metrics report to executives	Operations, Engineering, DPO
6 to 12 months	Warm standby region, security certification readiness (ISO 27001 and PCI DSS review), annual review cycle, internal audit of the programme	CEO, CISO

10.1 Key performance indicators

KPI	Target
Mean time to detect (all incidents)	Under 1 hour for SEV-1 and SEV-2
Mean time to contain	Under 4 hours for SEV-1 and SEV-2
Regulatory notifications on time	100%
Phishing simulation click rate	Below 5% within 6 months
MFA coverage of staff accounts	100%
Tier 1 restore tests passed	100% each quarter
DPIA high-risk actions completed on time	100%

Appendix A: Emergency Contact Sheet (to complete)

Role	Name	Mobile	Alternate	Email
Incident Commander				
Technical Lead				
Privacy Lead / DPO				
Compliance Lead				
Communications Lead				
Operations Lead				
CEO / Executive Sponsor				
DFIR retainer				
Cloud provider support				
Partner bank 1, 2, 3 contacts				
Legal counsel				
Cyber insurer				

Appendix B: Incident Log Template

Field	Entry
Incident ID and title	
Date and time detected (with time zone)	
Reported by	
Severity and classification	
Systems, accounts and data affected	
Personal data involved? (Y/N, categories, approximate numbers)	
Actions taken, with time and owner	
Decisions made and rationale	
Evidence collected (ID, hash, location)	
Notifications made (who, when, how)	
Status and next update time	
Lessons learned and actions	

Appendix C: Standards and References

- Nigeria Data Protection Act 2023 and applicable NDPC guidance
- Central Bank of Nigeria requirements for payment service providers, including risk-based cybersecurity framework and incident reporting circulars (confirm current versions)
- ISO/IEC 27001:2022, ISO/IEC 27035 (incident management), ISO 22301 (business continuity), ISO/IEC 29134 (privacy impact assessment)
- NIST SP 800-61 Rev. 2 and NIST Cybersecurity Framework
- PCI DSS (where card data is processed)